NexAI CRM (Kauflizenz) – Unterstützungszeitraum und Nutzerinformation

Erklärung zum Unterstützungszeitraum und Informationen und Anleitungen für Nutzer nach Anhang II der Cyberresilienz-Verordnung

Stand: Oktober 2026 · Vorlage – je Lizenzkauf ausfüllen und dem Kunden beim Kauf übergeben

Entwurf – von NexAI erstellt, anwaltliche Prüfung folgt. Angaben in eckigen Klammern sind beim Lizenzkauf auszufüllen oder vor der ersten Verwendung zu klären; „[setzt voraus: …]“ kennzeichnet Stellen, die erst wahr sind, wenn das Genannte umgesetzt ist.

A. Erklärung zum Unterstützungszeitraum

Kunde: [Firma, Anschrift]

Produkt: NexAI CRM (Kauflizenz, Betrieb auf einem Server des Kunden)

Version bei Übergabe: [Versionsnummer und Commit-Kennung]

Lizenznummer / Anzahl Zugänge: [Lizenznummer] / [Anzahl]

Tag des Lizenzkaufs: [TT.MM.JJJJ]

Ende des Unterstützungszeitraums (Sicherheitsaktualisierungen bis einschließlich): [MM/JJJJ – sieben Jahre nach dem Monat des Lizenzkaufs]

(1) NexAI stellt für das oben bezeichnete Produkt bis zum Ende des Unterstützungszeitraums **Sicherheitsaktualisierungen kostenlos** bereit. Das gilt unabhängig davon, ob der Kunde einen Pflegevertrag abgeschlossen hat.

(2) Der Unterstützungszeitraum beträgt **sieben Jahre ab dem Lizenzkauf**. Er verlängert sich nicht durch spätere Aktualisierungen und nicht durch den Abschluss oder die Verlängerung eines Pflegevertrags.

(3) Während des Unterstützungszeitraums erhält der Kunde **jeweils die neueste Version kostenlos**, einschließlich der Funktionsaktualisierungen. NexAI behebt Schwachstellen in der jeweils neuesten Version; das ist zulässig, weil der Kunde diese Version kostenlos erhält und ihm für die Anpassung seiner Hardware- und Softwareumgebung keine zusätzlichen Kosten entstehen (Art. 13 Abs. 10 CRA). [setzt voraus: neue Versionen laufen auf dem Server, auf dem der Kunde die ursprüngliche Version betreibt, ohne kostenpflichtige Erweiterung; andernfalls trägt NexAI die Mehrkosten oder liefert Sicherheitskorrekturen für die ältere Version.]

(4) Ein Pflegevertrag umfasst ausschließlich **Support und Reaktionszeiten** nach Anlage C (SLA). Sicherheits- und Funktionsaktualisierungen sind nicht an die Pflege gebunden.

(5) Jede Sicherheitsaktualisierung bleibt nach ihrer Bereitstellung mindestens zehn Jahre oder bis zum Ende des Unterstützungszeitraums abrufbar, je nachdem, welcher Zeitraum länger ist (Art. 13 Abs. 9 CRA), unter [Bezugsquelle].

(6) Nach dem Ende des Unterstützungszeitraums stellt NexAI für diese Lizenz keine Sicherheitsaktualisierungen mehr bereit. Das Produkt läuft weiter, wird aber mit der Zeit unsicherer. NexAI weist den Kunden [drei Monate] vorher per E-Mail darauf hin und zeigt beim Ende einen Hinweis in der Anwendung an [setzt voraus: Hinweis in der Anwendung, Art. 13 Abs. 19 UAbs. 2 CRA]. [Ob und zu welchen Bedingungen NexAI danach eine Verlängerung anbietet,

ist nicht entschieden.]

(7) Stellt NexAI den Geschäftsbetrieb ein und kann diese Zusagen deshalb nicht mehr erfüllen, informiert NexAI den Kunden vorher (Art. 13 Abs. 23 CRA).

(8) Die vertraglichen Einzelheiten zur Kauflizenz, zum Wartungszugang und zur Pflicht des Kunden, bereitgestellte Sicherheitsaktualisierungen in angemessener Frist einzuspielen, regelt Anlage E (Kauflizenz und Projektanwendungen).

B. Informationen und Anleitungen für Nutzer (Anhang II CRA)

1. Hersteller

NexAI – Next Generation Artificial Intelligence GbR, vertreten durch die Gesellschafter Maximilian Trenk und Jason Brian Merklein, Untere Bergstraße 13, 74586 Frankenhardt-Honhardt, Deutschland · E-Mail: mbt@nex-a-i.com · Telefon: 0176 80714816 · Website: https://nex-a-i.com

2. Zentrale Kontaktstelle für Schwachstellen

Schwachstellen melden Sie an **security@nex-a-i.com** [bis zur Einrichtung dieses Postfachs: mbt@nex-a-i.com], telefonisch unter 0176 80714816 (Mo–Fr 09:00–17:00 Uhr) oder per Post an die Anschrift unter Nr. 1. Unsere Richtlinie zur koordinierten Offenlegung von Schwachstellen finden Sie unter [https://nex-a-i.com/de/sicherheit]; die Kontaktangaben stehen auch unter https://nex-a-i.com/.well-known/security.txt.

3. Produkt

NexAI CRM, Software (Webanwendung in Containern zum Betrieb auf einem eigenen Server), Version [Versionsnummer], Commit-Kennung [Kennung]. Die installierte Version ist in der Anwendung unter [Menüpfad] ersichtlich [setzt voraus: Versionsanzeige in der Oberfläche und fortlaufende Versionsnummern].

4. Zweckbestimmung, Sicherheitsumfeld und Sicherheitseigenschaften

Zweckbestimmung: Verwaltung von Kunden- und Geschäftsbeziehungen in Unternehmen (B2B), insbesondere Kontakte, Firmen, Leads, Aufgaben, Termine sowie – je nach Lizenzumfang – Angebote und Rechnungen [Funktionsumfang laut Auftragsformular]. Bedient wird das Produkt von angemeldeten Mitarbeitern des Kunden über einen Webbrowser. Betrieben wird es auf einem vom Kunden gestellten Linux-Server mit Docker; der Kunde ist Betreiber der Installation und Verantwortlicher für die darin verarbeiteten Daten.

Von NexAI bereitgestelltes Sicherheitsumfeld:

- Installationsskript, das alle Schlüssel und Geheimnisse auf dem Server des Kunden erzeugt; sie verlassen den Server nicht;
- Container-Konfiguration mit vorgeschaltetem Reverse-Proxy und automatisch bezogenem TLS-Zertifikat; Datenbank und Zwischenspeicher liegen in einem internen Netz;
- Skripte für Datensicherung und Wiederherstellung.

Sicherheitseigenschaften des Produkts:

- Passwörter werden mit argon2id gespeichert; Zwei-Faktor-Anmeldung per Einmalcode-App (TOTP) [verpflichtend für: …];
- Rollen und Berechtigungen je Benutzer; Mandantentrennung in der Datenbank (Row-Level-Security);

- Geheimnisse der Zwei-Faktor-Anmeldung und Gesprächsmitschriften werden in der Datenbank zusätzlich feldweise verschlüsselt (AES-256-GCM);
- Begrenzung von Anmelde- und Schnittstellenaufrufen (Rate Limiting) und Sicherheits-Header;
- Änderungsprotokoll (Audit-Log) für sicherheitsrelevante Vorgänge.

5. Umstände mit erheblichen Cybersicherheitsrisiken

Erhebliche Risiken entstehen insbesondere, wenn

- bereitgestellte Sicherheitsaktualisierungen nicht eingespielt werden oder das Produkt nach dem Ende des Unterstützungszeitraums weiter betrieben wird;
- Datenbank, Zwischenspeicher oder Verwaltungsdienste durch Änderung der Netzwerkkonfiguration aus dem Internet erreichbar gemacht werden;
- die Zwei-Faktor-Anmeldung abgeschaltet wird, Zugänge von mehreren Personen geteilt oder schwache Passwörter verwendet werden oder Alltagsnutzer Administratorrechte erhalten;
- die Konfigurationsdatei mit Schlüsseln ungeschützt liegt, in eine Versionsverwaltung gelangt oder Datensicherungen unverschlüsselt bzw. nur auf demselben Server liegen;
- Betriebssystem, Docker oder die Firewall des Servers nicht aktuell gehalten werden;
- angebundene Drittdienste (Telefonie, E-Mail, Kalender, KI) mit weitreichenden Schlüsseln angebunden oder Freigabelinks (z. B. Kalender-Abonnements) an Unbefugte weitergegeben werden;
- der Programmcode oder die mitgelieferte Konfiguration verändert werden (siehe Nr. 8 b) oder nicht benötigte Zusatzdienste aktiviert bleiben.

6. EU-Konformitätserklärung

[Ab dem 11.12.2027: Internetadresse der EU-Konformitätserklärung.] Die Pflicht zur EU-Konformitätserklärung gilt ab dem 11.12.2027 (Art. 71 Abs. 2 CRA). Für die hier übergebene Version ist [noch] keine EU-Konformitätserklärung ausgestellt.

7. Technische Sicherheitsunterstützung und Ende des Unterstützungszeitraums

NexAI behandelt Schwachstellen nach der Richtlinie zur koordinierten Offenlegung, stellt Sicherheitsaktualisierungen kostenlos bereit und veröffentlicht nach jeder Behebung einen Sicherheitshinweis. Ist eine Schwachstelle aktiv ausgenutzt, informiert NexAI betroffene Kunden direkt, auch über Maßnahmen, die sie selbst ergreifen können. **Das Enddatum des Unterstützungszeitraums steht in Teil A.** Support mit Reaktionszeiten erhalten Kunden mit Pflegevertrag nach Anlage C.

8. Anleitungen

Ausführliche Anleitungen: [Internetadresse oder beigefügtes Betriebshandbuch].

a) Erste Inbetriebnahme und laufender Betrieb

- einen Server mit unterstütztem, aktuellem Linux und Docker verwenden; aus dem Internet nur die Ports 80 und 443 freigeben;
- die Installation mit dem mitgelieferten Installationsskript durchführen und die Konfigurationsdatei nur für Administratoren lesbar halten;
- den ersten Administratorzugang sofort mit starkem Passwort und Zwei-Faktor-Anmeldung absichern; für jede Person einen eigenen Zugang anlegen und Administratorrechte sparsam vergeben;

- die Datensicherung einrichten, die Sicherungen auf ein anderes System übertragen, den Schlüssel getrennt davon aufbewahren und die Wiederherstellung mindestens einmal ausprobieren;
- Sicherheitsaktualisierungen zeitnah einspielen (siehe c), Betriebssystem und Docker aktuell halten;
- Zugänge ausgeschiedener Mitarbeiter sofort sperren und das Änderungsprotokoll regelmäßig sichten.

b) Auswirkungen von Änderungen am Produkt: Änderungen am Programmcode, an der Container-Konfiguration oder an Umgebungsvariablen können Schutzmechanismen außer Kraft setzen, etwa die Mandantentrennung in der Datenbank, die TLS-Verschlüsselung oder die Begrenzung von Anmeldeversuchen. Sicherheitsaktualisierungen stellt NexAI für das unveränderte Produkt bereit; bei veränderten Installationen können sie fehlschlagen oder unwirksam sein. Auch Einstellungen in der Oberfläche (Rollen, Rechte, Freigabelinks, Anbindungen) bestimmen, wer auf welche Daten zugreifen kann.

c) Installation von Sicherheitsaktualisierungen: [setzt voraus: Ausrollweg für Kundeninstallationen (Anhang I Teil II Nr. 7 CRA) – noch nicht gebaut. Vorschlag: NexAI spielt Aktualisierungen über den vereinbarten Wartungszugang ein (Anlage E); ohne Wartungszugang führt der Kunde den Aktualisierungsbefehl aus: …]. Vor jeder Aktualisierung ist eine aktuelle Datensicherung anzulegen [setzt voraus: automatische Sicherung vor der Aktualisierung]. NexAI kündigt Sicherheitsaktualisierungen per E-Mail an die bei Kauf benannte technische Kontaktadresse an.

d) Sichere Außerbetriebnahme und Entfernen der Daten: (1) Daten exportieren und vorher prüfen, ob Unterlagen wie Rechnungen noch gesetzlich aufbewahrt werden müssen; (2) Schlüssel und Freigaben bei angebundenen Diensten (Telefonie, E-Mail, Kalender, KI) widerrufen und einen etwaigen Wartungszugang von NexAI entfernen; (3) die Dienste stoppen und die Datenträger der Container löschen (z. B. „docker compose --env-file .env -f infra/docker-compose.yml down -v“); (4) alle Datensicherungen auf allen Systemen löschen; (5) den Server bzw. seine Datenträger beim Hoster löschen oder sicher überschreiben und DNS-Einträge entfernen.

e) Automatische Sicherheitsaktualisierungen: Das Produkt installiert Sicherheitsaktualisierungen derzeit nicht automatisch. [Sobald eine automatische Installation als Standardeinstellung angeboten wird: Beschreibung, wie sie abgeschaltet oder vorübergehend verschoben werden kann.]

f) Integration in andere Produkte: Das NexAI CRM ist nicht zur Integration in andere Produkte bestimmt. Die Programmierschnittstelle dient der Anbindung eigener Systeme des Kunden; dabei sind Schlüssel mit den kleinstmöglichen Rechten zu verwenden.

9. Software-Stückliste

[Entscheidung offen: Stellt NexAI dem Kunden die Software-Stückliste (SBOM) zur Verfügung, steht hier, wo sie abrufbar ist. Andernfalls entfällt diese Nummer; die Pflicht, eine SBOM zu erstellen (Anhang I Teil II Nr. 1 CRA), bleibt davon unberührt.]

C. Rechtlicher Rahmen (Belege)

Pflicht	Fundstelle	Wortlaut (Auszug)
Enddatum beim Kauf angeben	Art. 13 Abs. 19 UAbs. 1 CRA	„… zum Zeitpunkt des Kaufs in leicht zugänglicher Weise … wobei mindestens der Monat und das Jahr anzugeben sind“
Mindestdauer	Art. 13 Abs. 8 UAbs. 3 CRA	„… beträgt der Unterstützungszeitraum mindestens fünf Jahre“
Sicherheitsaktualisierungen abrufbar halten	Art. 13 Abs. 9 CRA	„… für mindestens zehn Jahre oder für die verbleibende Dauer des Unterstützungszeitraums …“
Beschränkung auf die neueste Version	Art. 13 Abs. 10 CRA	„… sofern die Nutzer der zuvor in den Verkehr gebrachten Version kostenlos Zugang zu der zuletzt in den Verkehr gebrachten Version haben …“
Kostenlose, unverzügliche Verbreitung	Anhang I Teil II Nr. 8 CRA	„… unverzüglich und … kostenlos verbreitet werden, zusammen mit Hinweisen …“
Kontaktangaben des Herstellers	Art. 13 Abs. 16 CRA; Anhang II Nr. 1	„… die Postanschrift, die E-Mail-Adresse oder andere digitale Kontaktangaben …“
Zentrale Anlaufstelle	Art. 13 Abs. 17 CRA; Anhang II Nr. 2	„… eine zentrale Anlaufstelle, die es den Nutzern ermöglicht, direkt und schnell mit ihnen zu kommunizieren …“
Nutzerinformation beifügen, 10 Jahre verfügbar	Art. 13 Abs. 18 CRA	„… mindestens zehn Jahre lang oder für die Dauer des Unterstützungszeitraums …“
Geltungsbeginn	Art. 71 Abs. 2 CRA	„Diese Verordnung gilt ab dem 11. Dezember 2027. Artikel 14 gilt jedoch ab dem 11. September 2026 …“

Die Pflichten aus Art. 13 und Anhang II CRA gelten nach Art. 71 Abs. 2 CRA ab dem 11.12.2027. Für frühere Lizenzen erteilt NexAI diese Informationen und Zusagen freiwillig und vertraglich. Fundstelle: Verordnung (EU) 2024/2847, konsolidierte Fassung vom 20.11.2024 (EUR-Lex, CELEX 02024R2847-20241120), abgerufen am 18.10.2026.

Übergeben – für NexAI

Ort, Datum
Name / Funktion

Erhalten – für den Kunden

Ort, Datum
Name / Funktion